SecureBank Financial

SecureMobile Banking Platform

Quantitative Risk Assessment, Control Cost-Benefit Analysis and Executive Briefing

Prepared by	**Lead GRC Analyst, SecureBank Financial**
Prepared for	**Chief Information Security Officer (CISO); Chief Financial Officer (CFO)**
Date	**28 October 2026**
Source data	**SecureBank_Financial.pdf: 'Dataset: Mobile Banking Platform Assessment' (penetration test and vulnerability assessment)**
Companion file	**SecureBank_Risk_Model.xlsx**
Status	**DRAFT for CISO/CFO review.**

Phase 1: Risk Exposure Calculation

1. ALE calculations (SLE, ARO, ALE)

- F1:API Authentication Bypass

SLE = $5,000,000 (maximum single incident loss). ARO = 0.15. ALE = $5,000,000 x 0.15 = $750,000

- F2:Database Injection

SLE = 500,000 records x $250 = $125,000,000. ARO = 0.25. ALE = $125,000,000 x 0.25 = $31,250,000

- F3:Session Hijacking

SLE = 5,000 accounts x $1,500 = $7,500,000. ARO = 0.40. ALE = $7,500,000 x 0.40 = $3,000,000

Total ALE = $750,000 + $31,250,000 + $3,000,000 = $35,000,000

Vulnerability	SLE	ARO	ALE	Share of total
API Authentication Bypass	**$5,000,000**	**0.15**	**$750,000**	**2.1%**
Database Injection	**$125,000,000**	**0.25**	**$31,250,000**	**89.3%**
Session Hijacking	**$7,500,000**	**0.40**	**$3,000,000**	**8.6%**
Total			**$35,000,000**	**100.0%**

2. Risk prioritization matrix

No	Vulnerability	SLE	ARO	ALE	Heat-map rating	Priority level
1	Database Injection	$125,000,000	0.25	$31,250,000	High	Critical
2	Session Hijacking	$7,500,000	0.40	$3,000,000	High	High
3	API Authentication Bypass	$5,000,000	0.15	$750,000	Medium	Medium

Note: Priority level comes from ALE size (decision D9). The heat-map rating comes from probability and impact bands (D10). Both agree on order: Database Injection first, Session Hijacking second, API Authentication Bypass third.

3. Risk visualizations

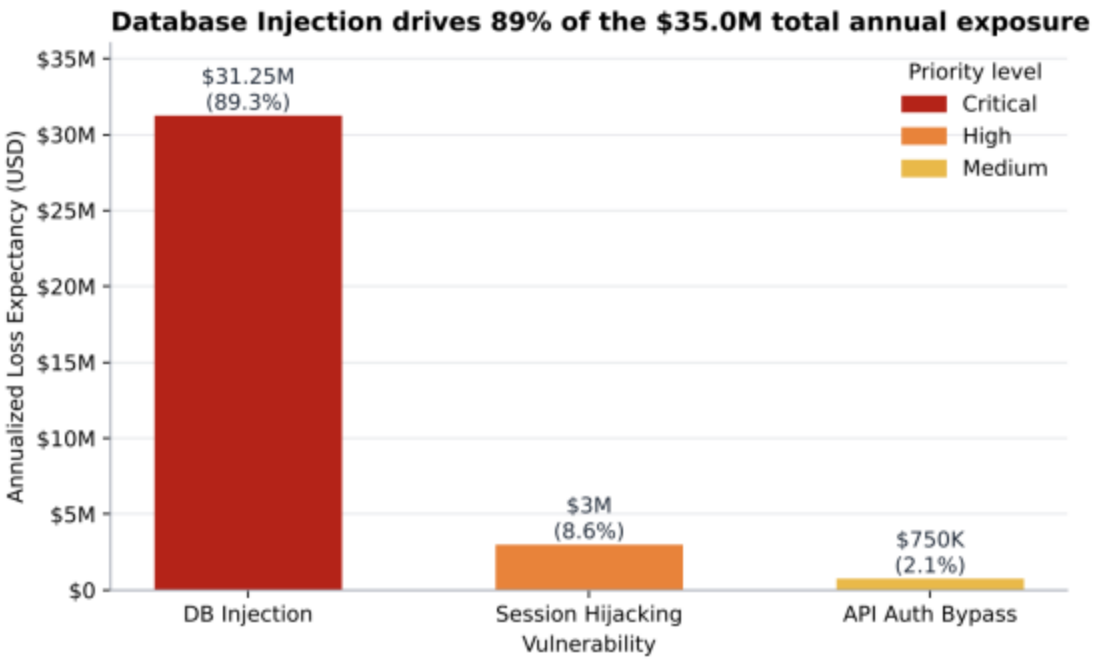


Figure 1. ALE by vulnerability. Colors show priority level (red = Critical, orange = High, yellow = Medium).

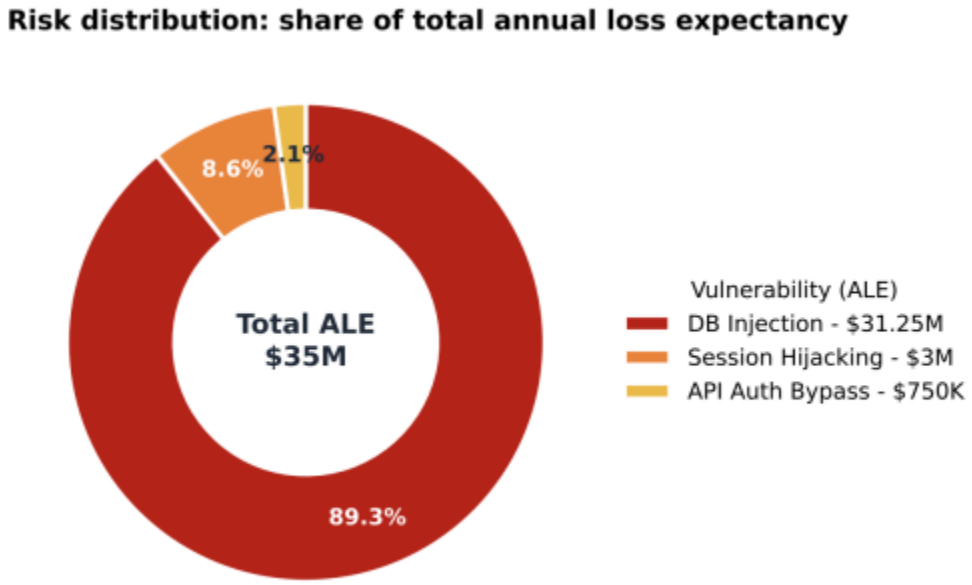
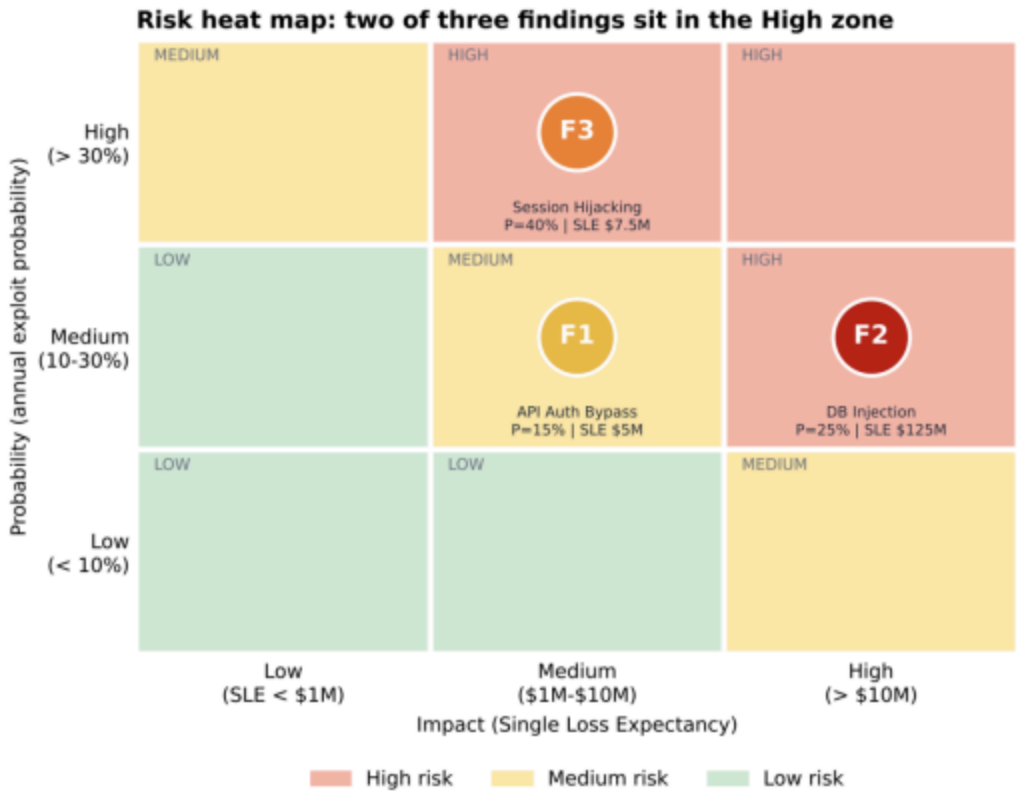


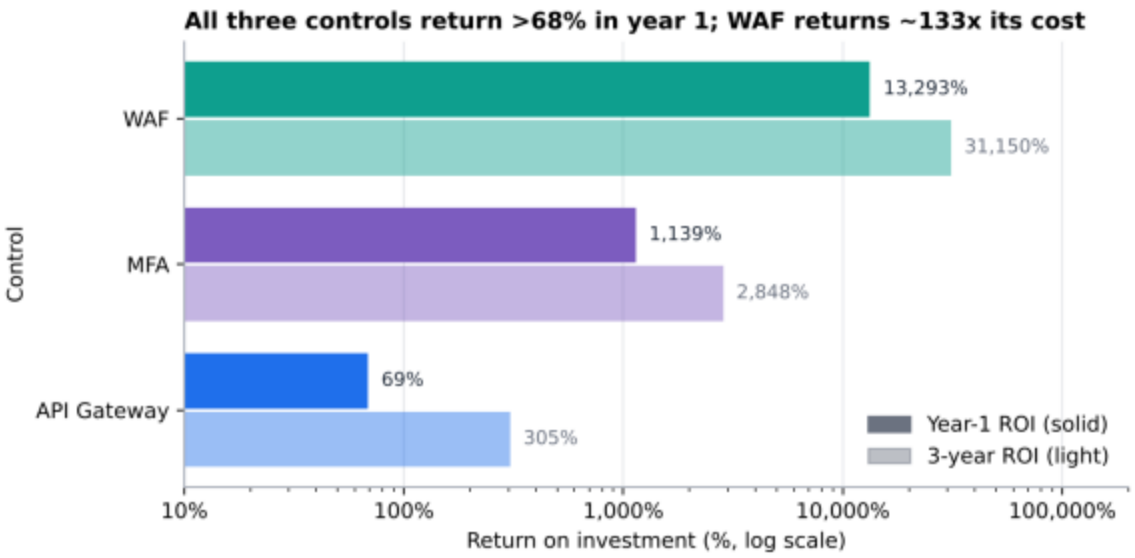
Figure 2. Share of total annual loss expectancy.

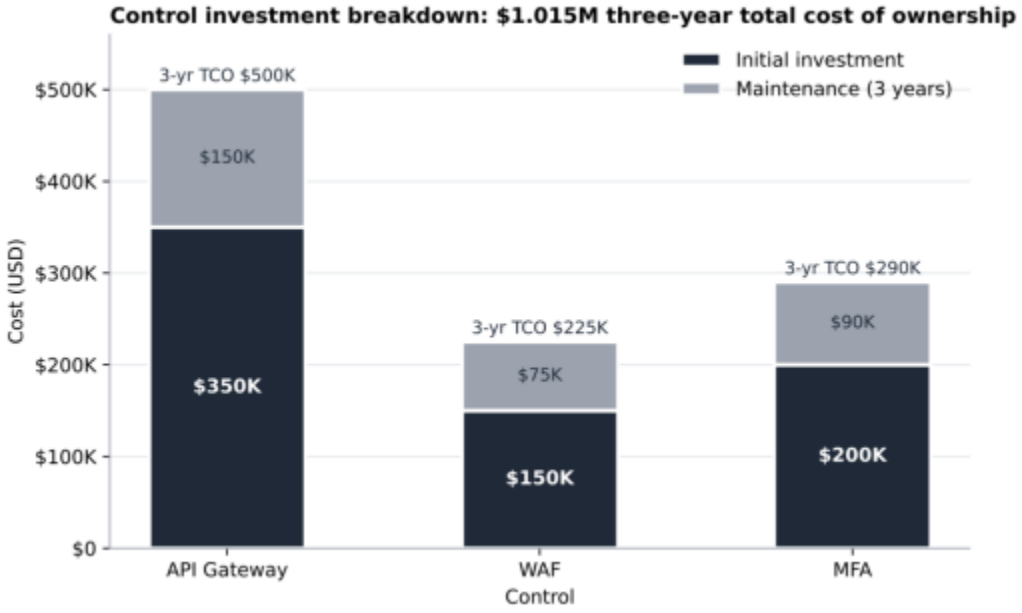


Phase 2: Control Evaluation

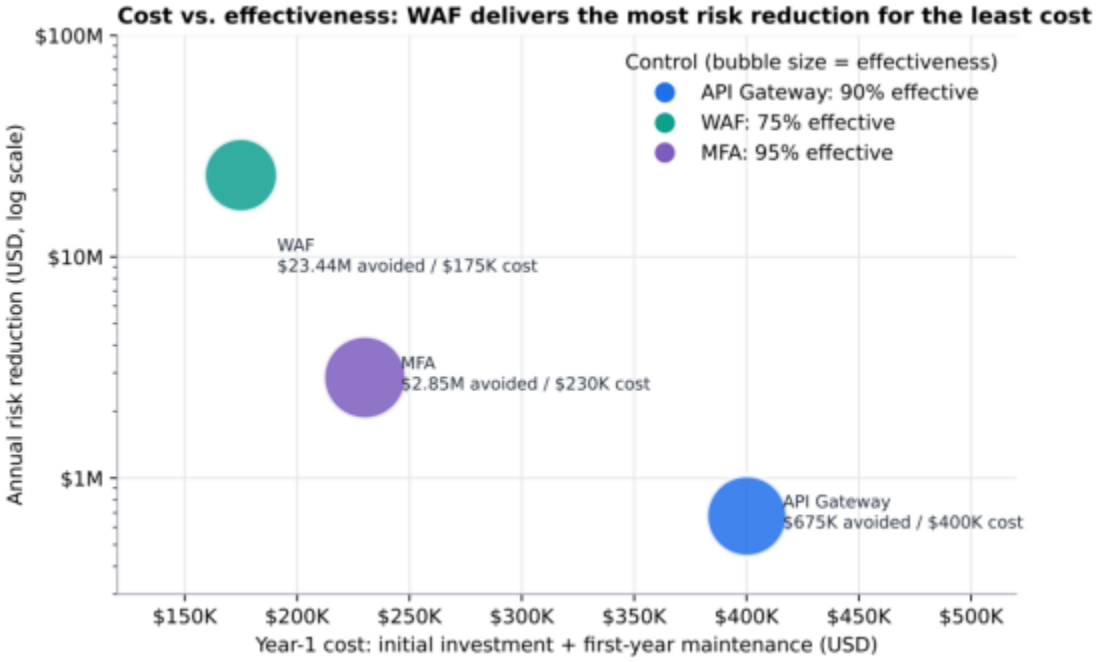
4. Control cost-benefit worksheet

Metric	API Security Gateway	WAF	MFA Enhancement
Mitigates	API Auth Bypass	DB Injection	Session Hijacking
Effectiveness	90%	75%	95%
Initial investment	$350,000	$150,000	$200,000
Annual maintenance	$50,000	$25,000	$30,000
ALE before control	$750,000	$31,250,000	$3,000,000
Risk reduction (annual $)	$675,000	$23,437,500	$2,850,000
Residual ALE	$75,000	$7,812,500	$150,000
Net annual benefit	$625,000	$23,412,500	$2,820,000
Year-1 cost	$400,000	$175,000	$230,000
3-year cost (TCO)	$500,000	$225,000	$290,000
Year-1 ROI	69%	13,293%	1,139%
3-year ROI	305%	31,150%	2,848%
Payback period	6.7 months (0.56 yr)	2 days (0.01 yr)	26 days (0.07 yr)

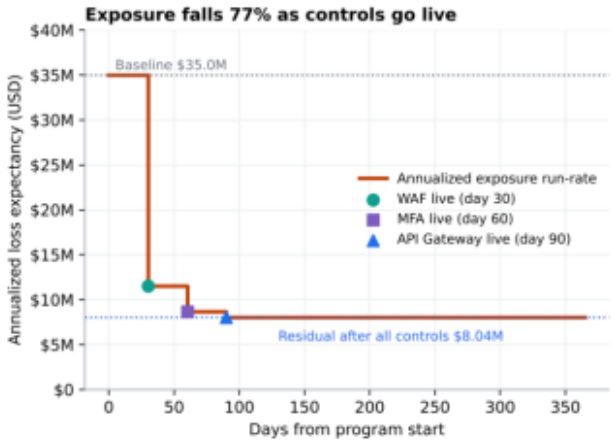

All three controls return >68% in year 1; WAF returns ~133x its cost
WAF
MFA
API Gateway
Control
13,293%
31,150%
1,139%
2,848%
69%
305%
Year-1 ROI (solid)
3-year ROI (light)
10%
100%
1,000%
10,000%
100,000%
Return on investment (%, log scale)

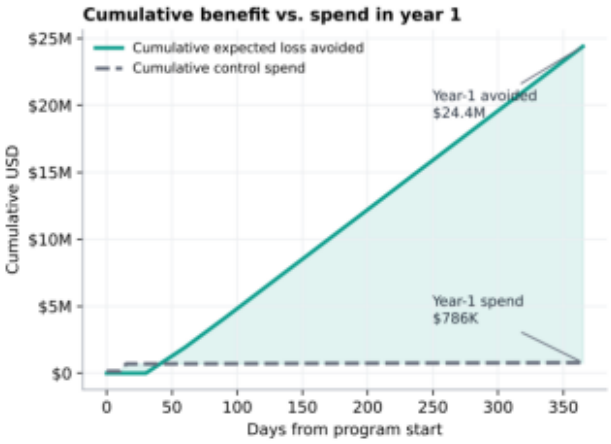

Control investment breakdown: $1.015M three-year total cost of ownership
Initial investment
Maintenance (3 years)
Cost (USD)
$500K
$400K
$300K
$200K
$100K
$0
3-yr TCO $500K
$150K
$350K
3-yr TCO $225K
$75K
$150K
3-yr TCO $290K
$90K
$200K
API Gateway
WAF
MFA
Control

5. Control selection analysis



Risk reduction over time (phased go-live: WAF d30, MFA d60, API Gateway d90)





Phase 3: Executive Reporting

6. Executive summary

The penetration test found three critical vulnerabilities that together put $35.0M a year of expected loss at risk. One flaw dominates: Database Injection is $31.25M (89%). It is priced at a full 500,000-record breach ($125M) with a 25% yearly chance. Session Hijacking is $3.0M and API Authentication Bypass is $750K.

The recommendation. Approve all three controls: $700K up front plus $105K a year (805K in year 1). They are expected to cut annual exposure by $26.96M (77%), to $8.04M.

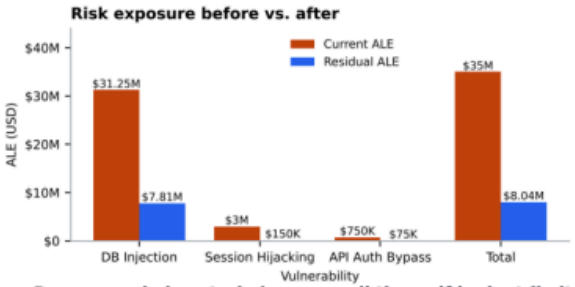
SecureMobile Banking Platform - Executive Risk Dashboard

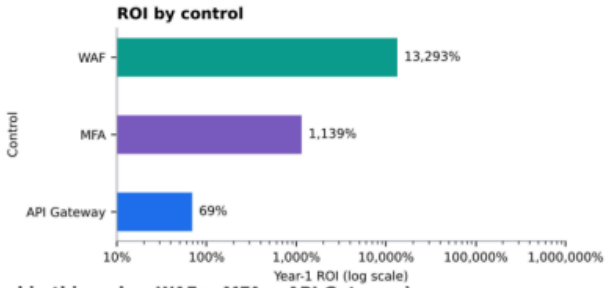
SecureBank Financial | GRC | Prepared for CISO & CFO | 28 Oct 2026 | Figures are annualized expected values (USD)

Current exposure (ALE)	Residual after controls	Risk reduction / yr	Investment (Yr-1 cash)	Portfolio Yr-1 ROI
$35M	$8.04M	$26.96M (77%)	$805K	3,249%

Top 3 risks by financial impact

#	Vulnerability	SLE	ARO	ALE	Share	Priority	Mitigating control	Residual ALE
1	Database Injection	$125M	0.25	$31.25M	89.3%	Critical	WAF	$7.81M
2	Session Hijacking	$7.5M	0.40	$3M	8.6%	High	MFA	$150K
3	API Authentication Bypass	$5M	0.15	$750K	2.1%	Medium	API Gateway	$75K





Recommended controls (approve all three; if budget-limited, fund in this order: WAF > MFA > API Gateway)

Control	Initial	Annual maint.	Risk reduction / yr	Yr-1 ROI	3-yr ROI	Payback	Go-live
Web Application Firewall (WAF)	$150K	$25K	$23.44M	13,293%	31,150%	2 days	Day 30
MFA Enhancement	$200K	$30K	$2.85M	1,139%	2,848%	26 days	Day 60
Advanced API Security Gateway	$350K	$50K	$675K	69%	305%	6.7 months	Day 90
TOTAL PORTFOLIO	**$700K**	**$105K**	**$26.96M**	**3,249%**	-	**~10 days***	**Day 90**

*Payback = initial investment / (annual risk reduction - annual maintenance), on an expected-value basis (losses accrue evenly). Individual payback for the API Gateway is ~6.7 months. Controls address distinct vulnerabilities; benefits are additive.

7. Risk treatment plan (Gantt) and financial justification

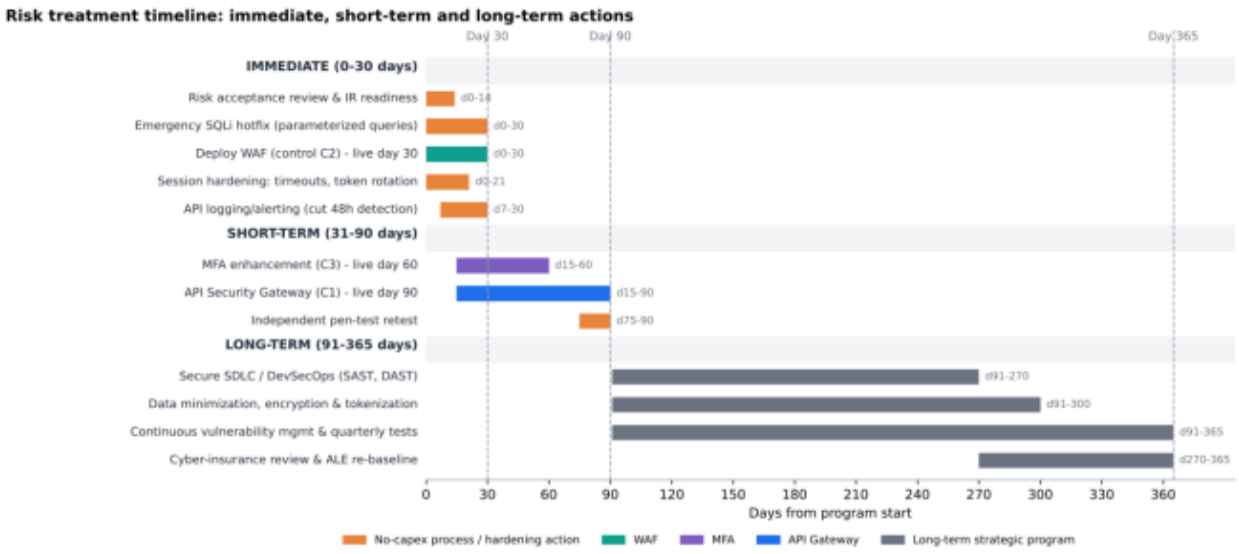


Figure 11. Risk treatment timeline. Orange bars are no-capex actions that are not costed in the dataset.

Phase	Action	Owner (proposed)	Outcome
Immediate (0-30 d)	Deploy WAF with injection rules in blocking mode	CISO / Infra	$23.44M a year of expected loss removed from day 30
Immediate (0-30 d)	Emergency fix of the injection flaw: parameterized queries, least-privilege DB account	Engineering	Removes root cause; WAF becomes second layer
Immediate (0-30 d)	Session hardening (short timeouts, token rotation, binding) and API logging/alerting	Engineering / SOC	Interim cut to Session and API risk; targets 48 h detection time
Immediate (0-30 d)	Formal risk-acceptance review; incident-response readiness check	GRC / CISO	Documented decisions for residual risk
Short-term (31-90 d)	MFA enhancement live by day 60	Identity / Product	$2.85M a year removed
Short-term (31-90 d)	API Security Gateway live by day 90; independent pen-test retest	Platform / CISO	$675K a year removed; verifies fixes
Long-term (91-365 d)	Secure SDLC (SAST/DAST in CI), data minimization, encryption and tokenization	Engineering / Data	Attacks the $7.81M residual database risk (not costed)
Long-term (91-365 d)	Quarterly testing, vulnerability management, cyber-insurance review, ALE re-baseline	GRC	Updated risk numbers for next budget cycle

Financial justification

- Spend: $700K initial + $105K a year maintenance. Year-1 cash outlay $805K; 3-year total cost $1.015M.
- Benefit: $26,962,500 a year of expected loss removed at full run-rate (77%). In the first 12 months, with phased go-live, expected loss avoided is $24,401,199 against $785,685 spent.

- Portfolio Year-1 ROI is 3,249%; 3-year ROI is 7,869%; portfolio payback is about 10 days on an expected-value basis.
- Spending nothing is not a $0 option: it carries a $35.0M expected annual loss. The cost of all controls is 2.3% of that figure.
- Even if the Database Injection breach affected only 10% of records, the WAF would still return about 1,240% in year 1.